WHITE PAPER DRAFT

Kyron eKYC

NIST IAL2-Aligned Remote Identity Proofing with Document Fraud Detection, Liveness, and Face ID Authentication

Prepared for internal product, security, and customer review | 2026-06-08

Positioning statement

Kyron should be described as NIST IAL2-aligned or designed toward NIST IAL2 readiness. This draft does not assert NIST certification, ISO certification, or external laboratory validation.

Executive Summary

Kyron eKYC is a web-first identity verification platform designed to verify document evidence, bind the applicant to the document portrait through face matching, test live presence through active and passive liveness controls, and support returning-user Face ID authentication for future banking or payment-style flows.

The product direction is aligned with the structure of NIST SP 800-63-4: identity proofing is addressed under Identity Assurance Level 2 (IAL2), returning-user authentication is addressed separately under Authentication Assurance Level controls, and biometric attack resistance is evaluated through presentation attack detection testing.

The current implementation is a strong prototype, but a formal production claim requires additional evidence: privacy notices and consent records, encrypted biometric-template storage, authenticated administrative APIs, audit logs, calibrated model thresholds, independent PAD and biometric testing, and security operations controls.

1. Scope and Intended Use

This white paper frames Kyron as a remote onboarding and returning-user authentication system for organizations that need document proofing, live-user assurance, and biometric profile reuse. The current workflow is suitable for demonstrations and controlled pilots. Production financial services use should add multi-factor authentication, device binding, transaction confirmation, and formal security/privacy governance.

- Primary onboarding evidence: passport and Lao ID card capture from upload or camera.
- Primary biometric checks: active face liveness, passive selfie liveness, face comparison, and Face ID login.
- Primary decision output: pass, reject, or pending with explainable scores and reason codes.
- Storage principle: store verification results and verified profile fields; avoid raw media retention by default.

2. Standards Basis

The standards below provide the recommended reference model for the product white paper and future compliance roadmap.

Standard / Guidance	Relevance to Kyron	How it should be used
NIST SP 800-63-4	Digital identity framework covering identity proofing, authentication, and federation.	Use as the top-level framework. Avoid saying certified unless independently assessed.
NIST SP 800-63A	Enrollment and identity proofing, including IAL2 proofing expectations.	Map document evidence, validation, biometric binding, fraud checks, privacy, and redress.
NIST SP 800-63B	Authentication and authenticator management.	Use for returning Face ID login, MFA, replay resistance, throttling, and authenticator binding.
ISO/IEC 30107-3	Biometric presentation attack detection testing and reporting.	Use to evaluate phone screen, tablet, printed photo, mask, and video replay resistance.
ISO/IEC 19795-1	Biometric performance testing and reporting.	Use for face match false match, false non-match, and demographic/device performance reports.
ISO/IEC 24745	Biometric information protection.	Use for encrypted, revocable, and privacy-protective face-template storage.
ISO/IEC 27001 and 27701	Information security and privacy management systems.	Use for governance, policies, risk management, incident response, and privacy controls.
FATF Digital Identity Guidance	Risk-based digital identity guidance for customer due diligence.	Use for financial-sector positioning, risk scoring, and ongoing due diligence context.

3. Target End-to-End Workflow

1. Start: user chooses new-user signup or returning-user Face ID login.
2. Document capture: user uploads or captures passport / Lao ID evidence with camera guidance.
3. Document analysis: backend checks image quality, document likeness, OCR/MRZ fields, expiry, and fraud signals.
4. Active liveness: user performs randomized face actions such as blink, turn left/right, or open mouth.

5. Gesture challenge: user performs randomized hand gestures in a randomized on-screen target area.
6. Selfie verification: backend checks selfie quality, passive liveness, screen/print replay cues, and face match.
7. Risk decision: app returns pass, reject, or pending with reason codes and scores.
8. Enrollment: if passed, user can enroll one active Face ID linked to one verified profile.
9. Returning login or payment flow: user submits a live face check and matches against the stored profile.

4. NIST IAL2 Alignment Matrix

IAL2 area	Current Kyron capability	Required hardening for stronger readiness
Identity evidence capture	Camera/upload capture for passport and Lao ID; upload size and content-type controls.	Add capture-quality guidance, device metadata, secure capture telemetry, and clear retention notices.
Evidence validation	OCR/MRZ extraction, expiry checks, document-shape and fraud heuristics.	Add authoritative or cryptographic validation where available, stronger security-feature checks, and validation logs.
Applicant binding	Document portrait embedding compared with live selfie embedding.	Calibrate face-match thresholds with formal FMR/FNMR reports and demographic/device testing.
Liveness and PAD	Active face challenges, gesture challenge, passive anti-spoofing, and multi-frame selfie burst.	Run ISO/IEC 30107-3-style PAD evaluation on print, screen, tablet, video replay, and mask attacks.
Fraud decisioning	Automatic pass/reject/pending, scores, and reason codes.	Add manual review, redress workflow, model-version evidence, and threshold-change approval records.
Privacy and consent	No raw media storage by default; public demo warning.	Add explicit consent capture, biometric-use notice, retention limits, deletion/export workflows, and DPIA.
Records and auditability	Verification result metadata and profile records.	Add immutable audit logs for enrollment, decisions, login, deletion, admin access, model versions, and risk changes.

5. Security and Fraud Detection Controls

5.1 Document Fraud Detection

The document layer should detect expired documents, unreadable MRZ/OCR, non-document uploads, printed copies, screen recapture, portrait substitution, text overlay, image manipulation, and low-quality captures. For IAL2 readiness, Kyron should separate weak-quality failures from high-confidence fraud failures so genuine users are not over-rejected.

5.2 Active Liveness

Active liveness should require randomized actions and server-verified evidence bursts. The backend should not trust frontend landmark motion alone. Strong replay signals, repeated static display texture, or visible screen/tablet cues should cause rejection or manual review.

5.3 Passive Liveness and Selfie Burst

Passive selfie liveness should use a short burst rather than a single frame. This lets the system compare texture, motion, lighting variation, repeated display edges, glare, moire patterns, and model spoof scores across frames.

5.4 Face Matching and Face ID

Face matching should report calibrated genuine-match and impostor-match performance. Returning-user Face ID should be treated as a biometric factor, not as a complete bank-grade authenticator by itself. For payment or transfer, Kyron should combine Face ID with device binding, PIN/passkey/WebAuthn, transaction confirmation, rate limits, and risk scoring.

6. Biometric Data Protection

Production requirement

Face templates and verified identity attributes should be encrypted at rest, protected by access controls, covered by explicit consent, and governed by retention/deletion workflows. Raw identity media should remain disabled by default.

- Encrypt face templates and sensitive profile attributes using KMS or envelope encryption.
- Record consent version, timestamp, biometric purpose, and retention period.
- Support account deletion, biometric-template deletion, profile export, and retention expiry.
- Protect admin endpoints with authentication, authorization, throttling, and audit logging.
- Separate demo/test data from production data and prevent public demo uploads of sensitive real documents.

7. Testing and Evidence Plan

A credible IAL2-alignment claim depends on evidence. The project should maintain test datasets, evaluation scripts, threshold history, model versions, and repeatable reports.

Test domain	Representative cases	Metrics to report
Document proofing	Real camera passport, real camera Lao ID, printed passport copy, printed ID copy, edited portrait, text overlay, expired evidence, non-document upload.	Accuracy, false reject rate, false accept rate, MRZ/OCR read rate, expiry extraction accuracy.
Active liveness	Real face, phone replay, tablet/laptop replay, video replay, low light, glasses, partial face, wrong action.	Attack presentation classification error rate, bona fide rejection, challenge pass latency.
Passive selfie PAD	Real live selfie, phone screen photo, tablet/laptop screen, printed photo, paper attack, video replay, no-valid-face.	PAD pass/fail accuracy, false accept rate, false reject rate, score distributions by device.
Face matching	Same-person document/selfie pairs, impostor pairs, look-alike pairs, aging/lighting/device variation.	False match rate, false non-match rate, threshold curve, demographic/device breakdown.

Face login should be tested separately with returning users, wrong users, duplicate-profile attempts, spoof login attempts, multiple-face frames, low-confidence faces, lockout behavior, and average login latency.

8. Production Readiness Roadmap

Phase 1: Security Hardening

- Protect profile/admin endpoints with authenticated role-based access.
- Encrypt biometric templates and sensitive identity attributes.
- Add audit log tables and event capture for decisions, enrollment, login, deletion, and admin actions.
- Add consent, retention, deletion, and privacy-notice workflows.

Phase 2: Model Calibration and Dataset Evidence

- Finalize document, selfie PAD, active liveness, and face-match test datasets.
- Generate repeatable accuracy reports and threshold recommendations.
- Document false accepts, false rejects, known edge cases, and manual-review triggers.

Phase 3: Operational Controls

- Add monitoring, alerting, backups, incident response, secrets management, and dependency scanning.
- Run penetration testing and privacy impact assessment before broader customer use.
- Prepare ISO/IEC 27001/27701 policies if the organization wants formal certification.

Phase 4: Independent Review

- Perform external PAD/biometric evaluation against ISO/IEC 30107-3 and ISO/IEC 19795-1 style reporting.
- Review NIST IAL2 alignment matrix with an identity/security assessor.
- Update customer-facing claims only after evidence is collected and reviewed.

9. Recommended Customer-Facing Claim Language

Recommended wording

Kyron eKYC is designed as a NIST IAL2-aligned remote identity proofing workflow using document evidence validation, active/passive liveness, face matching, and explainable fraud-risk decisioning. Certification and conformity claims should be made only after independent assessment.

Avoid wording: do not say NIST IAL2 certified, ISO certified, bank-grade certified, or government-approved unless an external assessment is complete.

10. Current Limitations

- Document validation is still model- and heuristic-driven; authoritative issuer validation is not yet integrated.
- Face templates require production-grade encryption and key management.
- Profile admin APIs are suitable for demos only until protected by authentication and authorization.
- PAD and face-match thresholds need larger datasets and documented false reject / false accept tradeoffs.
- Payment or transfer flows require MFA and transaction controls; face alone is not enough for high-risk banking use.
- Formal claims require independent review, audit evidence, privacy documentation, and operational security controls.

References

- NIST SP 800-63-4, Digital Identity Guidelines: https://pages.nist.gov/800-63-4/sp800-63.html
- NIST SP 800-63A, Enrollment and Identity Proofing: https://pages.nist.gov/800-63-4/sp800-63a.html
- NIST SP 800-63B, Authentication and Authenticator Management: https://pages.nist.gov/800-63-4/sp800-63b.html
- NIST IAL2 Remote Identity Proofing implementation resources: https://pages.nist.gov/800-63-3-Implementation-Resources/63A/ial2remote/
- ISO/IEC 30107-3:2023, Biometric presentation attack detection: https://www.iso.org/standard/79520.html
- ISO/IEC 19795-1:2021, Biometric performance testing and reporting: https://www.iso.org/standard/73515.html
- ISO/IEC 24745:2022, Biometric information protection: https://www.iso.org/standard/75302.html
- ISO/IEC 27001:2022, Information security management systems: https://www.iso.org/standard/27001
- ISO/IEC 27701:2025, Privacy information management systems: https://www.iso.org/standard/85819.html
- FATF Guidance on Digital Identity: https://www.fatf-gafi.org/en/publications/Financialinclusionandnpoissues/Digital-identity-guidance.html